

- **Use compliance scanning:** Integrate compliance scanning tools to ensure adherence to regulatory requirements.
- **Embed security in culture:** Foster a security-first culture across development, security, and operations teams, making security a top priority throughout the development process.

Organisations must regularly review and update security objectives and tools to address evolving threats. Figure 2 illustrates a few principles that should guide your DevSecOps implementation journey. By embracing these principles, your organisation can ensure a robust and effective implementation of DevSecOps that integrates security at every stage of the software development and delivery process. This approach not only minimises risks but also enhances the overall quality and reliability of the product.

Things to consider when implementing DevSecOps

To ensure successful execution of DevSecOps, there are a few things you should keep in mind.

- **Integration:** It's essential to ensure that the open source tools you choose can be seamlessly integrated with your existing development tools and workflows. This will

help to minimise disruptions and improve productivity.

- **Scalability:** As your organisation grows, your open source tools should be able to scale with it. Choose tools that can handle increasing workloads without compromising on performance or security.
- **Community support:** Tools with active communities and extensive documentation are more likely to receive regular updates and bug fixes, making them a more secure and reliable choice.
- **Compatibility:** Make sure that the open source tools you select are compatible with the operating systems, platforms, and environments that your organisation uses.
- **Customisation:** Look for open source tools that offer flexibility and customisation options, allowing your teams to tailor them to their specific needs.
- **Cost:** Don't forget to evaluate the total cost of ownership, including support, maintenance, and upgrades, when selecting open source tools for your DevSecOps process.
- **Security:** Assess the security posture and vulnerability management of the open source tools you're considering to ensure they meet your organisation's security requirements.

- **Compliance:** Make sure that the open source tools you choose meet the relevant regulatory and compliance requirements.
- **Training and support:** Providing adequate training and support for your teams is essential for utilising the open source tools you've selected effectively.
- **Continuous monitoring:** Regularly monitoring and updating your open source tools is necessary to address evolving threats and vulnerabilities.
- **Vendor lock-in:** Be aware of the risk of vendor lock-in and choose open source tools with open standards and interoperability.
- **Data privacy:** Ensure that the open source tools you choose comply with data privacy regulations and protect sensitive data.
- **Incident response:** Establishing incident response plans and procedures for security breaches is essential to minimise the impact of any potential threats.
- **Collaboration:** Foster collaboration between development, security, and operations teams to improve communication and enhance the overall security posture of your organisation.
- **Continuous improvement:** Regularly reviewing and refining your



Figure 2: Security guiding principles for DevSecOps